Definitions - S

PURPOSE: This document provides a list of words and definitions to clarify Information Specific (IT) terminology contained within the State of Wyoming Policies and Standards.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

- Safeguards: Protective measures prescribed to meet the security requirements (i.e., confidentiality, integrity, and availability) specified for an information system. Safeguards may include security features, management constraints, personnel security, and security of physical structures, areas, and devices. Synonymous with security controls and countermeasures. (SOURCE: NIST SP 800-53; NIST SP 800-37; FIPS 200; CNSSI-4009)

- Safety: Condition of being protected from harm or other undesirable outcomes. (SOURCE: Wikipedia)

- Sanitization: Process to remove information from media such that information recovery is not possible. It includes removing all labels, markings, and activity logs. (SOURCE: FIPS 200) A general term referring to the actions taken to render data written on media unrecoverable by both ordinary and, for some forms of sanitization, extraordinary means. (SOURCE: NIST SP 80053; CNSSI-4009)

- Scalability: The ability of a system, network, or process to handle a growing amount of work in a capable manner or its ability to be enlarged to accommodate that growth. (SOURCE: WIKIPEDIA)

- Scanning: Sending packets or requests to another system to gain information to be used in a subsequent attack. (SOURCE: CNSSI-4009)

- Scoping: Process of identifying all system components, people, and processes to be included in an assessment. The first step of an assessment is to accurately determine the scope of the review. (SOURCE: PCI DSS GLOSSARY)

- Secure Coding Guidelines: Philosophy and approach supporting the practice of developing computer software in a way that guards against the accidental introduction of security vulnerabilities. Defects, bugs, and logic flaws are consistently the primary cause of commonly exploited software vulnerabilities. Through the analysis of thousands of reported vulnerabilities, security professionals have discovered that most vulnerabilities stem from a relatively small number of common software programming errors. By identifying the insecure coding practices that lead to these errors and educating developers on secure alternatives, organizations can take proactive steps to help significantly reduce or eliminate vulnerabilities in software before deployment. (SOURCE: Wikipedia)

- Security: A condition that results from the establishment and maintenance of protective measures that enable an enterprise to perform its mission or critical functions despite risks posed by threats to its use of information systems. Protective measures may involve a combination of deterrence, avoidance, prevention, detection, recovery, and correction that shall form part of the enterprise's risk management approach. (SOURCE: CNSSI-4009)

- Security Control Assessment: The testing and/or evaluation of the management, operational, and technical security controls in an information system to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for the system. (SOURCE: NIST SP 800-37; NIST SP 800-53; NIST SP 800-53A; CNSSI-4009)

- Security Control Baseline: The set of minimum security controls defined for a low-impact, moderate-impact, or high-impact information system. (SOURCE: NIST SP 800-53; FIPS 200)

- Security Control Effectiveness: The measure of correctness of implementation (i.e., how consistently the control implementation complies with the security plan) and how well the security plan meets organizational needs in accordance with current risk tolerance. (SOURCE: NIST SP 800-137)

- Security Controls: The management, operational, and technical controls (i.e., safeguards or countermeasures) prescribed for an information system to protect the confidentiality, integrity, and availability of the system and its information. (SOURCE: NIST SP 800-53; NIST SP 800-37; NIST SP 800-53A; NIST SP 800-60; FIPS 200; FIPS 199; CNSSI-4009)

- Security Impact Analysis: The analysis conducted by an organizational official to determine the extent to which changes to the information system have affected the security state of the system. (SOURCE: NIST SP 800-53; NIST SP 800-53A; NIST SP 800-37; CNSSI-4009)

- Security Information and Event Management (SIEM) Tool: Application that provides the ability to gather security data from information system components and present that data as actionable information via a single interface. (SOURCE: NIST SP 800-128)

- Security Objective: Confidentiality, integrity, or availability. (SOURCE: NIST SP 800-53; NIST SP 800-53A; NIST SP 800-60; NIST SP 800-37; FIPS 200; FIPS 199)

- Security Plan: Formal document that provides an overview of the security requirements for an information system or an information security program and describes the security controls in place or planned for meeting those requirements. See ‘System Security Plan’ or ‘Information Security Program Plan.’ (SOURCE: NIST SP 800-53; NIST SP 800-53A; NIST SP 800-37; NIST SP 800-18)

- Security Policy: The statement of required protection of the information objects. (SOURCE: NIST SP 800-27) A set of criteria for the provision of security services. It defines and constrains the activities of a data processing facility in order to

maintain a condition of security for systems and data. (SOURCE: FIPS 188; (SOURCE: NIST SP 800-37; NIST SP 800-53; CNSSI-4009)

- Security Requirements: Requirements levied on an information system that are derived from applicable laws, Executive Orders, directives, policies, standards, instructions, regulations, or procedures, or organizational mission/business case needs to ensure the confidentiality, integrity, and availability of the information being processed, stored, or transmitted. (SOURCE: FIPS 200; NIST SP 800-53; NIST SP 800-53A; NIST SP 800-37; CNSSI-4009)

- Security Safeguards: Protective measures and controls prescribed to meet the security requirements specified for an information system. Safeguards may include security features, management constraints, personnel security, and security of physical structures, areas, and devices. (SOURCE: CNSSI-4009)

- Secure System Development Lifecycle (SSDLC): The process model used to build secure applications.

- Security Testing: Process to determine that an information system protects data and maintains functionality as intended. (SOURCE: CNSSI-4009)

- Sensitive Data: Data that is private, personal, or proprietary and must be protected from unauthorized access. (SOURCE: Data Governance Institute)

- Sensitive Information: A term to describe any information which requires protection from unauthorized access or disclosure.

- Sensitivity: The degree to which an IT system or application requires protection (to ensure confidentiality, integrity, and availability) is determined by an evaluation of the nature and criticality of the data processed, the relation of the system to the organization's missions, and the economic value of the system components.

- Separation of Duties: Practice of dividing steps in a function among different individuals so as to keep a single individual from being able to subvert the process. (SOURCE: PCI DSS GLOSSARY)

- Service: A capability provided by an information system that facilitates information processing, storage, or transmission. Also referred to as an information system service.

- Service Organization Control (SOC) - 1 Report: These reports, prepared in accordance with Statement on Standards for Attestation Engagements (SSAE) No. 16, Reporting on Controls at a Service Organization, are specifically intended to meet the needs of the management of user affiliates and the user affiliates' auditors, as they evaluate the effect of the controls at the service organization on the user affiliates' financial statement assertions. These reports are important components of user affiliates' evaluation of their internal controls over financial reporting for purposes of compliance with laws and regulations such as the Sarbanes-Oxley Act and the user affiliates' auditors as they plan and perform audits of the user affiliates' financial statements. There are two types of reports for these engagements:
    - Type 1 – report on the fairness of the presentation of management's description of the service organization's system and the suitability of the design of the controls to achieve the related control objectives included in the description as of a specified date.
    - Type 2 – report on the fairness of the presentation of management's description of the service organization's system and the suitability of the design and operating effectiveness of the controls to achieve the related control objectives included in the description throughout a specified period. The use of these reports is restricted to the management of the service organization, user affiliates of the service organization, and user auditors. (SOURCE: AICPA Website)

- Service Organization Control (SOC) - 2 Report: These reports are intended to meet the needs of a broad range of users who need information and assurance about the controls at a service organization that affect the security, availability, and processing integrity of the systems the service organization uses to process users' data and the confidentiality and privacy of the information processed by these systems. Examples of stakeholders who may need these reports are management or those charged with governance of the user affiliates and the service organization, customers of the service organization, regulators, business partners, suppliers, and others who have an understanding of the service organization and its controls. Use of these reports generally is restricted to parties that have this

understanding. The AICPA Guide: Reports on Controls at a Service Organization Relevant to Security, Availability, Processing Integrity, Confidentiality, or Privacy (currently under development) provides guidance for performing these engagements. These reports can play an important role in:

- Oversight of the organization
- Affiliate management programs
- Internal corporate governance and risk management processes
- Regulatory oversight

Similar to a SOC 1 report there are two types of report: A type 2, report on management's description of a service organization's system and the suitability of the design and operating effectiveness of controls; and a type 1, report on management's description of a service organization's system and the suitability of the design of controls. Use of these reports is generally restricted. (SOURCE: AICPA Website)

- Service Organization Control (SOC) - 3 Report: These reports are designed to meet the needs of users who need assurance about the controls at a service organization that affect the security, availability, and processing integrity of the systems used by a service organization to process users' information, and the confidentiality, or privacy of that information, but do not have the need for or the knowledge necessary to make effective use of a SOC 2 Report. These reports are prepared using the AICPA/Canadian Institute of Chartered Accountants (CICA) Trust Services Principles, Criteria, and Illustrations for Security, Availability, Processing Integrity, Confidentiality, and Privacy. Because they are general-use reports, SOC 3 reports can be freely distributed or posted on a website as a SysTrust for Service Organizations seal. For more information about the SysTrust for Service Organization seal program, go to www.webtrust.org. (SOURCE: AICPA Website)

- Service-Level Agreement (SLA): Defines the specific responsibilities of the service provider and sets the customer expectations. (SOURCE: CNSSI-4009)

- Session: A semi-permanent interactive information interchange, also known as a dialogue, a conversation, or a meeting, between two or more communicating devices or between a computer and a user (see Login session). A session is set up or established at a certain point in time and then torn down at some later point. An established communication session may involve more than one message in each

direction. A session is typically, but not always, stateful, meaning that at least one of the communicating parts needs to save information about the session history in order to be able to communicate, as opposed to stateless communication, where the communication consists of independent requests with responses. (SOURCE: Wikipedia)

- Single Point of Failure: A resource whose loss will result in the loss of service or production. (SOURCE: ISACA)

- Smartphone: A handheld mobile communication device with a mobile operating system, integrated mobile broadband cellular network, and Wi-Fi connection capability used for voice and data communications. (SOURCE: Wikipedia)

- Social Engineering: An attempt to trick someone into revealing information (e.g., a password) that can be used to attack systems or networks. (SOURCE: NIST SP 800-61; CNSSI-4009) A general term for attackers trying to trick people into revealing sensitive information or performing certain actions, such as downloading and executing files that appear to be benign but are actually malicious. (SOURCE: NIST SP 800-114) The process of attempting to trick someone into revealing information (e.g., a password). (SOURCE: NIST SP 800-115)

- Social Media: The interaction among people in which they create, share, or exchange information and ideas in virtual communities and networks. (SOURCE: Wikipedia)

- Social Networking: Use of a platform/service to support collaboration among people who share interests, activities, backgrounds, or real-life connections. A social network service consists of a representation of each user (often a profile), his social links, and a variety of additional services. Social networking is web-based services that allows individuals to create a public profile, to create a list of users with whom to share connection, and view and cross the connections within the system. Most social network services are web-based and provide means for users to interact over the Internet, such as e-mail and instant messaging. Social network sites are varied, and they incorporate new information and communication tools such as mobile connectivity, photo/video/sharing and blogging. Online community services are sometimes considered social network services, though, in a broader sense, social network services usually means an

individual-centered service, whereas online community services are group-centered. Social networking sites allow users to share ideas, pictures, posts, activities, events, and interests with people in their network. (SOURCE: Wikipedia)

- Software: Computer programs and associated data that may be dynamically written or modified during execution. (SOURCE: NIST)

- Software Development Life Cycle (SDLC): Acronym for “system development life cycle” or “software development lifecycle.” Phases of the development of a software or computer system that includes planning, analysis, design, testing, and implementation. (SOURCE: PCI DSS GLOSSARY)

- Source Code: Uncompiled computer program code files generated by developers at the behest of or on behalf of the State of Wyoming.

- Source Code Repository - The enterprise solution provided by ETS to store and manage source code.

- Source Code Manager - State Employee that controls the process, application, or program associated with a collection of source code.

- Source Code Repository Manager - ETS employee who manages the enterprise code repository solution.

- Spam: The abuse of electronic messaging systems to indiscriminately send unsolicited bulk messages. (SOURCE: NIST NIST SP 800-53) Unsolicited bulk commercial email messages. (SOURCE: NIST NIST SP 800-45) Electronic junk mail or the abuse of electronic messaging systems to indiscriminately send unsolicited bulk messages. (SOURCE: CNSSI-4009)

- Special Character: Any non-alphanumeric character that can be rendered on a standard American-English keyboard. Use of a specific special character may be application-dependent. The list of special characters follows: ` ~ ! @ # $ % ^ & * ( ) _ + | } { “ : ? > < [ ] \ ; ’ , . / - = (SOURCE: CNSSI-4009)

- Spyware: Software that covertly gathers user information through the user's Internet connection without the user's knowledge. Spyware applications are typically bundled as a hidden component of freeware or shareware programs that can be downloaded from the Internet. Once installed, the spyware monitors user activity on the Internet and transmits that information in the background to someone else. Software that is secretly or surreptitiously installed into an information system to gather information on individuals or organizations without their knowledge is a type of malicious code. (SOURCE: NIST SP 800-53; CNSSI-4009)

- Staging Environment (System): Similar to the production environment where all the pre-production testing is conducted to ensure proper intended operation functionality.

- Stakeholder: Anyone who has a responsibility for, an expectation from, or some other interest in the enterprise. (SOURCE: ISACA GLOSSARY)

- Strong Authentication: The requirement to use multiple factors for authentication and advanced technology, such as dynamic passwords or digital certificates, to verify an affiliate's identity. (SOURCE: CNSSI-4009)

- Strong Password: A minimum of fourteen characters using a combination of upper and lowercase letters, numbers, and special characters.

- Subject Matter Expert (SME): A person who is an authority in a particular area or topic. (SOURCE: Wikipedia)

- System: Any organized assembly of resources and procedures united and regulated by interaction or interdependence to accomplish a set of specific functions. (SOURCE: CNSSI-4009) A system is defined as a discrete set of information technologies, including computer hardware, software, databases, etc., organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information. (SOURCE: NIST)

- System Administrator: A person who manages the technical aspects of a system. (SOURCE: NIST SP 800-40) Individual responsible for the installation and maintenance of an information system, providing effective information system utilization, adequate security parameters, and sound implementation of

established Information Assurance policies and procedures. (SOURCE: CNSSI-4009)

- System Assets: Any software, hardware, data, administrative, physical, communications, or personnel resource within an information system. (SOURCE: CNSSI-4009)

- System of Record - A data management term for an information storage system that is the authoritative data source for a given data element or piece of information.

- System Security Plan: Formal document that provides an overview of the security requirements for the information system and describes the security controls in place or planned for meeting those requirements. (SOURCE: NIST SP 800-37; NIST SP 800-53; NIST SP 800-53A; NIST SP 800-18; FIPS 200) The formal document prepared by the information system owner (or common security controls owner for inherited controls) that provides an overview of the security requirements for the system and describes the security controls in place or planned for meeting those requirements. The plan can also contain supporting appendices or references, as well as other key security-related documents such as a risk assessment, privacy impact assessment, system interconnection agreements, contingency plan, security configurations, configuration management plan, and incident response plan. (SOURCE: CNSSI-4009)

- System Software: The special software within the cryptographic boundary (e.g., operating system, compilers, or utility programs) designed for a specific computer system or family of computer systems to facilitate the operation and maintenance of the computer system, associated programs, and data. (SOURCE: FIPS 140-2)

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	SUBMITTED BY	APPROVED BY	ISSUED DATE	EFFECTIVE DATE

REVISIONS		
LAST REVISION DATE	LAST REVISED BY	LAST APPROVED BY

REVIEWS		
LAST REVIEW DATE	LAST REVIEWED BY	NEXT REVIEW DATE